

시정 요구 / 개선 요구

1. 제 목 : 개인정보파일 등록 및 업무시스템 접속기록 관리 불철저
2. 소관부점 : 정보시스템실(정보보안부)
3. 내 용 :

가. 업무개요

정보시스템실은 「업무분장세칙」 제13조 제3항에 따라 정보보안부를 두고 정보보안업무 및 정보보호업무를 총괄 수행하고 있고

정보보안부는 공사 고객에 대한 정보를 안전하게 보관·관리하기 위해 「개인정보 및 신용보호세칙」(이하 “세칙”이라 한다) 을 운영하고 있다.

나. 관계 법령·내규 및 판단 기준

「개인정보 보호법」 제31조 및 세칙 제7조에 따르면 개인정보 보호 책임자(정보보안부장)는 개인정보 관리 및 보호 실태와 관행에 대한 정기적인 조사 및 개선을 하여야 한다고 되어 있고

같은 법 제32조 및 세칙 제33조에 따르면 개인정보 보호책임자는 개인정보파일¹⁾을 운용하는 경우 개인정보파일의 명칭 등²⁾의 사항을 개인정보보호위원회에 등록 및 공개³⁾하여야 한다고 되어 있다.

1) 개인정보를 쉽게 검색할 수 있도록 일정한 규칙에 따라 체계적으로 배열하거나 구성한 개인정보의 집합물로 대표적으로 데이터베이스 테이블이 있음

2) 개인정보파일의 명칭, 운영 근거 및 목적, 개인정보 항목, 처리방침, 보유기간, 지속적으로 제공받는 자(제3자 제공), 그 밖의 개인정보 처리에 관한 사항

또한, 세칙 제7조 및 제40조에 따르면 개인정보 보호책임자는 개인정보취급자⁴⁾의 개인정보처리시스템(업무시스템) 접속기록을 연1회 이상 점검하여야 하고 점검한 내용은 위·변조 및 도난, 분실이 되지 않도록 보관·관리(접속 ID 등⁵⁾)하여야 한다고 되어 있다.

따라서, 개인정보 보호책임자는 공사 고객의 개인정보 관리 및 보호를 위하여 정기적으로 개인정보파일 운용현황을 점검하여 개인정보파일이 존재하는 업무시스템을 개인정보보호위원회에 등록하여야 하며, 업무시스템별 개인정보취급자의 접속기록을 주기적으로 점검·보관·관리하여야 한다.

다. 감사결과 확인된 문제점

그런데 감사일 현재 개인정보파일 등록 및 업무시스템 접속기록 관리 현황을 점검한 결과

(1) 개인정보파일 등록 및 업무시스템 접속기록 관리 불철저

♫♫♫ 홈페이지의 경우 회원가입 시 ◆◆회원과 ▽▽▽회원의 개인정보(성명, 주소, 연락처 등⁶⁾)를 수집하고 있으므로 「개인정보 보호법」 제32조 및 세칙 33조에 따라 개인정보파일 목록을 개인정보보호위원회에

3) 「개인정보보호법」 제30조에 따라 공사홈페이지에 개인정보파일 목록(개인정보파일 명칭, 운영 근거 등이 기재됨)을 등록하여 공개하고 있음

4) 개인(신용)정보를 처리하는 임직원으로 업무시스템 사용자를 뜻함

5) 접속ID, 접속일시, 접속자 IP주소, 수행업무(조회, 입력, 수정, 삭제, 출력 등), 처리한 정보주체의 정보

6) 회원가입 시 약관에 개인정보 수집 및 이용 동의를 통해 개인정보 수집 사실을 안내하고 성명, 주소, 연락처, 이메일, 부서, 직위, 아이디, 비밀번호를 수집하고 있음

등록하고 홈페이지에 개인정보파일을 공개하여야 하나, 공사 홈페이지 등에 공개된 개인정보처리방침의 개인정보파일 목록⁷⁾에는 ♀♀♀의 개인정보파일 등록이 누락된 사실이 있고

정보보안부의 ‘2022년 개인정보파일 현황검토요청(공익신고 관련)’ 전자결재 문서상에도 공사가 보유한 개인정보파일은 온비드 등 7건(업무시스템 기준 9건)으로 ♀♀♀ 홈페이지의 개인정보파일은 관리하지 않은 것으로 확인되었다.

또한, 정보시스템실에서 공사 업무시스템의 데이터베이스(DB) 관련 정보를 관리하는 데이터 품질관리시스템⁸⁾을 기준⁹⁾으로 개인정보 데이터를 보유한 업무시스템 현황을 파악한 결과, [표 25]와 같이 ♀♀♀, ●●●●● ●●●●● 등 5개 시스템에서 개인정보파일 237건의 테이블이 검출되었으나 정보보안부가 개인정보보호위원회에 등록한 개인정보파일 목록에는 ♀♀♀ 등 5개 업무시스템이 등록되지 않은 사실이 있다.

7) 개인정보파일 목록

업무시스템(9건)		개인정보파일(7건)	
순 번	명 칭	순 번	명 칭
1	“기재생략”	1	“기재생략”
2		2	
3		3	
4			
5			
6		4	
7		5	
8		6	
9		7	

8) 공사의 데이터 사전, 데이터베이스(DB) 구조를 관리하는 시스템으로 공사 업무시스템 전반에 대한 정보가 담겨 있음

9) 데이터 사전 기준 개인정보로 추정할 수 있는 ‘주민등록번호, 생년월일, 전화번호, 휴대전화, 이름, 성명’ 등의 단어가 2개 이상 포함된 데이터베이스 테이블(데이터베이스의 저장 공간 명칭) 목록 추출

[표 25] 품질관리시스템 기준 개인정보파일 보유 업무시스템 현황

(단위 : 개)

순 번	업무시스템	개인정보파일 (테이블 수)	개인정보 항목
합 계 : 5		237	
1		“기재생략”	
2			
3			
4			
5			

또한, 세척 제7조 및 제40조에 따르면 위의 [표 25]와 같이 ♡♡♡ 등 개인정보를 처리하는 5개 업무시스템에 대한 개인정보처리자의 접속 기록을 점검·관리·보관하여야 하나, 정보보안부의 「(7월) 개인정보처리 시스템 접속기록점검 결과보고(정보시스템실-xxxxx, 2022. 8. 16.)」를 확인한 결과, 개인정보보호위원회에 등록한 업무시스템의 개인정보파일 목록에 대해서만 접속기록을 점검·관리·보관하고 있었으며, 위의 5개 업무 시스템에 대해서는 관리하지 않은 사실이 있다.

(2) 개인정보파일 등록 및 접속기록 관리절차 개선 필요

위 (1)항과 같은 문제의 발생 원인은 세척에 따른 개인정보파일 등록의 주체가 분임 개인정보 책임자¹⁰⁾에게 있다는 점과 공사 내부에서 자체 개발한 업무시스템의 경우 업무시스템을 구축하는 과정에서 정보보안부 협조(타당성 검토 등) 절차를 누락하여 발생한 것으로 확인되었다.

10) 업무시스템 개발요청 부점장

따라서, 고객의 개인정보를 안전하게 보관·관리하기 위해서는 ① 주기적으로 데이터 품질관리시스템을 활용하여 개인정보파일을 보유한 업무 시스템 현황을 점검하고, ② 정보시스템실의 내부 시스템심의회¹¹⁾ 개최 현황을 점검하여 정보보안부의 협조 없이 구축된 시스템을 파악하는 등 개인정보파일 등록 및 접속기록 관리 절차를 개선할 필요가 있다.

[소관부점 의견] 정보보안부는 개인정보파일 등록 누락방지를 위하여 개인정보보호 법령 및 개인정보취급자(개인(신용)정보를 처리하는 임직원)의 의무 등에 대한 안내 및 교육 강화 필요성은 공감하나, 개인정보파일 등록 신청은 개인정보취급자의 역할이므로 개인정보 보호책임자(정보보안부장)에게 등록 신청하지 않은 경우 개인정보 보호책임자가 확인하기 어려운 점이 있다고 답변하였다.

하지만, 세칙에 따르면 개인정보 보호책임자는 개인정보파일의 보호 및 관리·감독의 업무를 수행하여야 한다고 되어 있으므로, 개인정보파일 목록에 등록하고 개인정보 접속기록을 관리하도록 요구할 필요가 있다.

4. 조치할 사항

정보시스템실장(정보보안부장)은 개인정보파일이 검출된 ♀♀♀ 등 5개 업무시스템에 대하여 개인정보파일 목록에 등록하고 개인정보 접속기록을 관리하도록 하며 (시정)

데이터 품질관리시스템과 정보시스템실 내부 시스템심의회를 활용하여 개인정보파일 목록 및 개인정보 접속기록을 점검하는 업무절차를 개선하시기 바랍니다. (개선)

11) 「정보화업무요강」 제14조 및 제16조에 따라 도입추정금액이 1억 원을 초과하는 사업의 경우 시스템심의회를 통해 사전평가를 실시함